

CYBERSECURITY-LABS

INFORMATION SECURITY

LAB REPORT



POLÍTICAS DE SEGURIDAD FÍSICA, AMBIENTAL Y OPERATIVAS

Informe de práctica

Víctor José Santos Guzmán

Information Security

Cybersecurity / Cloud / Networks / GRC



DESARROLLO

- Políticas de Seguridad Operativa

1.1 Política de Gestión de Accesos Basada en Roles (RBAC)

Objetivo

Diseñe esta política con el objetivo de establecer un modelo de control de acceso donde cada usuario tenga únicamente los permisos necesarios para realizar sus funciones dentro de la universidad. La implementación de un modelo basado en roles permite evitar accesos excesivos y reduce la posibilidad de que una persona pueda consultar o modificar información que no corresponde a sus responsabilidades.

Alcance

Esta política aplica para todos los usuarios que tengan acceso a los sistemas tecnológicos de la universidad, incluyendo:

- Estudiantes
- Profesores
- Personal administrativo
- Administradores de sistemas
- Personal externo autorizado

También aplica para sistemas críticos como:

- Sistema de gestión de aprendizaje (LMS)
- ERP académico
- Repositorio académico
- Laboratorios virtuales
- Servicios en la nube\

Desarrollo de la política

Actualmente, la universidad permite accesos remotos mediante VPN, pero no cuenta con una

segmentación adecuada ni reglas específicas según el tipo de usuario. Esto representa un riesgo

porque un usuario podría obtener permisos superiores a los necesarios y acceder a información académica sensible.

Para corregir esta situación, se debe implementar un modelo RBAC donde los permisos sean

asignados según el rol que tenga cada persona dentro de la institución.

Por ejemplo:

Rol de estudiante:

- Acceso únicamente a materiales académicos asignados
- Consulta de calificaciones propias
- Uso de laboratorios virtuales autorizados

Rol de profesor:

1. Administración de sus cursos
2. Publicación de contenido académico
3. Consulta de información relacionada con sus estudiantes

Rol administrativo:

1. Acceso a sistemas administrativos según sus funciones

Rol administrador de tecnología:

1. Administración de servidores
2. Gestión de infraestructura
3. Configuración de seguridad

Además, se deben realizar revisiones periódicas de permisos para verificar que los usuarios mantengan solamente los accesos necesarios. Cuando un empleado o estudiante abandone la institución, sus permisos deben ser eliminados inmediatamente.

Justificación

Considero que esta política es necesaria porque uno de los incidentes identificados fue el acceso indebido a notas académicas. Si no existe una correcta administración de permisos, cualquier cuenta comprometida podría representar una amenaza para la información institucional.

La aplicación de RBAC ayuda a cumplir el principio de mínimo privilegio, reduciendo la superficie de ataque y evitando movimientos no autorizados dentro de los sistemas.

1.2 Política de Autenticación Multifactor (MFA)

Objetivo

El objetivo de esta política es fortalecer el proceso de autenticación de los usuarios mediante un segundo factor de verificación, evitando que una contraseña comprometida sea suficiente para obtener acceso a los sistemas.

Alcance

Esta política aplica principalmente para:

1. VPN institucional
2. Cuentas administrativas
3. LMS
4. ERP académico
5. Servicios en la nube
6. Sistemas con información sensible

Desarrollo de la política

Durante el análisis del caso se identificó una filtración de credenciales causada por phishing. Esto demuestra que depender únicamente de contraseñas no es suficiente, ya que un atacante puede obtenerlas mediante técnicas de ingeniería social.

Por esta razón, la universidad debe implementar autenticación multifactor obligatoria.

Los métodos permitidos pueden incluir:

1. Aplicaciones autenticadoras
2. Códigos temporales
3. Llaves físicas de seguridad
4. Sistemas biométricos cuando sea necesario

Además, las cuentas administrativas deben tener controles más estrictos debido al nivel de privilegios que poseen.

También se deben establecer medidas como:

1. Prohibición del uso de contraseñas compartidas
2. Cambio de contraseñas comprometidas
3. Bloqueo de cuentas después de múltiples intentos fallidos
4. Capacitación contra ataques de phishing

Justificación

La implementación de MFA reduce considerablemente el riesgo de accesos no autorizados, incluso cuando una contraseña ha sido expuesta. En una universidad donde se manejan datos académicos y personales, este control es fundamental para proteger la identidad digital de los usuarios.

1.3 Política de Uso de Dispositivos Personales y Corporativos (BYOD)

Objetivo

Establecer las condiciones de seguridad necesarias para permitir el uso de dispositivos personales y equipos propiedad de la universidad.

Alcance

Aplica para:

2. Profesores internacionales
3. Personal administrativo
4. Estudiantes autorizados
5. Equipos corporativos

Desarrollo de la política

Actualmente, algunos profesores utilizan dispositivos personales sin una configuración estándar de seguridad. Esto representa un riesgo porque un equipo sin protección puede convertirse en un punto de entrada para ataques.

Los dispositivos que accedan a recursos institucionales deben cumplir requisitos mínimos:

- Sistema operativo actualizado
- Antivirus activo
- Protección mediante contraseña
- Cifrado del almacenamiento
- Bloqueo automático de pantalla
- No almacenar información sensible sin autorización

En el caso de equipos corporativos, la universidad debe mantener un registro donde se identifique:

3. Usuario responsable
4. Modelo del equipo
5. Número de inventario
6. Ubicación
7. Estado del dispositivo

Justificación

Esta política es importante debido al incidente donde ocurrió el robo de una laptop sin cifrado. Si un equipo perdido contiene información institucional, una persona no autorizada podría acceder a documentos sensibles.

El cifrado y la correcta administración de dispositivos reducen el impacto de estos eventos.

1.4 Política de Monitoreo y Registro de Eventos (Logs y SIEM)

Objetivo

Garantizar que las actividades realizadas dentro de los sistemas puedan ser registradas, monitoreadas y analizadas para detectar comportamientos sospechosos.

Desarrollo de la política

Actualmente, la universidad no realiza auditorías constantes de los registros de acceso. Esto dificulta identificar cuándo ocurre una actividad no autorizada.

Los sistemas críticos deben registrar eventos como:

- Inicio y cierre de sesión
- Intentos fallidos de acceso
- Cambios de configuración
- Acciones administrativas
- Descarga de información sensible

Estos registros deben almacenarse de forma centralizada mediante una solución SIEM (Security Information and Event Management), permitiendo correlacionar eventos y generar alertas.

También se deben establecer revisiones periódicas para identificar posibles incidentes.

Justificación

Los registros permiten conocer qué ocurrió, cuándo ocurrió y quién realizó una acción determinada. Sin una correcta administración de logs, investigar un incidente de seguridad puede ser mucho más difícil.

1.5 Política de Gestión de Incidentes de Seguridad

Objetivo

Establecer un procedimiento organizado para responder ante eventos que afecten la seguridad de la información.

Desarrollo de la política

La universidad debe contar con un proceso definido para manejar incidentes como:

- 1.** Phishing
- 2.** Robo de equipos
- 3.** Acceso indebido a información
- 4.** Malware
- 5.** Fallas de sistemas críticos

El proceso debe incluir:

Identificación: detectar y confirmar el incidente.

Contención: limitar el impacto evitando que el problema continúe.

Erradicación: eliminar la causa del incidente.

Recuperación: restaurar los servicios afectados.

Análisis posterior: documentar lo ocurrido y mejorar los controles.

Justificación

Una institución educativa depende de sus sistemas tecnológicos para funcionar. Una respuesta organizada permite reducir tiempos de recuperación y evitar que un incidente pequeño se convierta en un problema mayor.

1.6 Política de Gestión de Activos Tecnológicos

Objetivo

Crear un control completo sobre todos los activos tecnológicos pertenecientes o utilizados por la universidad.

Desarrollo de la política

Uno de los principales problemas encontrados es la falta de inventario formal de equipos como:

2. Computadoras
3. Laptops
4. Servidores
5. Tablets
6. Equipos de red
7. Servicios en la nube

La universidad debe implementar un inventario actualizado donde cada activo tenga:

3. Código de identificación
4. Responsable asignado
5. Ubicación
6. Estado
7. Fecha de adquisición

4. Sistema operativo
5. Nivel de criticidad

También se deben utilizar etiquetas físicas para facilitar la identificación.

Justificación

No es posible proteger correctamente un recurso que no se conoce. La gestión de activos permite tener visibilidad sobre la infraestructura y facilita aplicar controles de seguridad adecuados.